PRIVACY IMPACT ASSESSMENT REPORT

FIRST COMMUNITY COOPERATIVE

May 13, 2019

STRICTLY PRIVATE AND CONFIDENTIAL

First Community Cooperative
FICCO Main Office, Fernandez – Corrales St.,
Cagayan de Oro City,
Philippines, 9000

Attention: **Shiellou P. Jabonga**
Data Protection Officer

Gentlemen:

A privacy impact assessment (PIA) was performed on First Community Cooperative (hereinafter referred to as "FICCO" or "the Cooperative") from May 28, 2018 to October 18, 2018 toward compliance with Republic Act No. 10173 otherwise known as the Data Privacy Act of 2012 ("the Act"), its IRR and other issuances of the National Privacy Commission (NPC).

This document is a compilation of the results of the analyses made during the assessment as well as the earlier presentation results to the FICCO management.

This document should not, without our prior written consent, be made available to any third party or be used for any purpose other than in connection with the validation of the assessment in accordance with the confidentiality measures of the Cooperative.

We assume no responsibility whatsoever in respect of or arising out of or in connection with the contents of this report to parties other than the Cooperative. If others choose to rely in any way on the contents of this report, they may do so entirely at their own risk.

We thank the FICCO Management for the opportunity to have participated in the Cooperative's Data Privacy law compliance activities. We look forward to working with you again for your future requirements.

Very truly yours,

Mildred R. Ramos
Managing Partner, Advisory Services

TABLE OF CONTENTS

INTRODUCTION 4
SCOPE OF THE ASSESSMENT 5
DATA PRIVACY GOVERNANCE ASSESSMENT 12
DATA PRIVACY MANAGEMENT ASSESSMENT 14
PRIVACY RISK ASSESSMENT 20
PRIORITY ACTION PLAN 23
SIGN-OFF 25

APPENDICES
- A THRESHOLD ANALYSIS
- B PRIVACY GOVERNANCE ASSESSMENT
- C PRIVACY MANAGEMENT ASSESSMENT
  - C.01 ADMINISTRATIVE DEPARTMENT
  - C.02 ASSET MANAGEMENT DEPARTMENT
  - C.03 EDUCATION AND TRAINING COMMITTEE
  - C.04 FINANCE DEPARTMENT
  - C.05 HUMAN RESOURCE DEPARTMENT
  - C.06 INFORMATION TECHNOLOGY DEPARTMENT
  - C.07 INSURANCE AND NON-BANKING DEPARTMENT
  - C.08 INTERNAL AUDIT DEPARTMENT
  - C.09 LEGAL DEPARTMENT
  - C.10 BRANCH OPERATIONS – ACCOUNTING
  - C.11 BRANCH OPERATIONS – CASH MANAGEMENT
  - C.12 BRANCH OPERATIONS – COLLECTIONS
  - C.13 BRANCH OPERATIONS – LOANS
- D RISK ASSESSMENT AND TREATMENT PLAN
  - D.01 CRITICALITY ASSESSMENT
  - D.02 RISK DETAILS AND MITIGATION

ANNEXES
- A PRIVACY IMPACT ASSESSMENT METHODOLOGY
- B NPC RISK ASSESSMENT METHODOLOGY

GLOSSARY OF TERMS

Part 1
INTRODUCTION

A privacy impact assessment (PIA) was performed on the Cooperative's processes toward First Community Cooperative's (hereinafter referred to as "the Cooperative" or "FICCO") compliance with Republic Act No. 10173, also known as Data Privacy Act of 2012 ("the Act").

This report documents the results of the assessment of the potential impact of the Act on the processes of the Cooperative. The assessment performed covers only the policies, procedures and practices existing as of May 31, 2018. Details of the assessment, including the risks identified, were discussed and confirmed with functional units performing personal data processing and the Risk management unit of the Cooperative in separate meetings during the period July 30, 2018 to October 18, 2018

The corresponding action plans to address the risks identified during the assessment are likewise documented in this PIA report.

Part 2
SCOPE OF THE ASSESSMENT

The privacy impact assessment covered the processes of the Cooperative's functional units that involve personal information and sensitive personal information.

In order to determine which processes were to be included in the PIA, a threshold analysis was performed, the results of which are detailed in Appendix 1.0. The Threshold Analysis covered all of the Cooperative's divisions and departments and their respective processes that involve personal data.

Figure 1 on the next page presents the different business processes included in this PIA. The processes in blue are those that are managed by FICCO as Personal Information Controller (PIC), while the process in red (insurance and non-banking services) is managed by FICCO as Personal Information Processor (PIP) for Cooperative Insurance System of the Philippines (CISP) for life insurance policies, R&B Insurance, Inc. for non-life insurance policies, and Cooperative Health Management Federation (CHMF) for health insurance policies.

Non-banking services managed by the Cooperative in its capacity as PIP are Globe Telecom's GCASH Services, Land Bank of the Philippines' Distribution of 4Ps Assistance from the National Government, Skydirect's Credit Subscription of Sky Cable Services, and Shell and Petron's Credit Purchases for Fuel.

The business processes identified in the Threshold Analysis were converted into data processing systems (DPS) as defined by the Act in order to facilitate the registration of FICCO with the National Privacy Commission, pursuant to the requirements of Section 46a and 47 of the IRR.

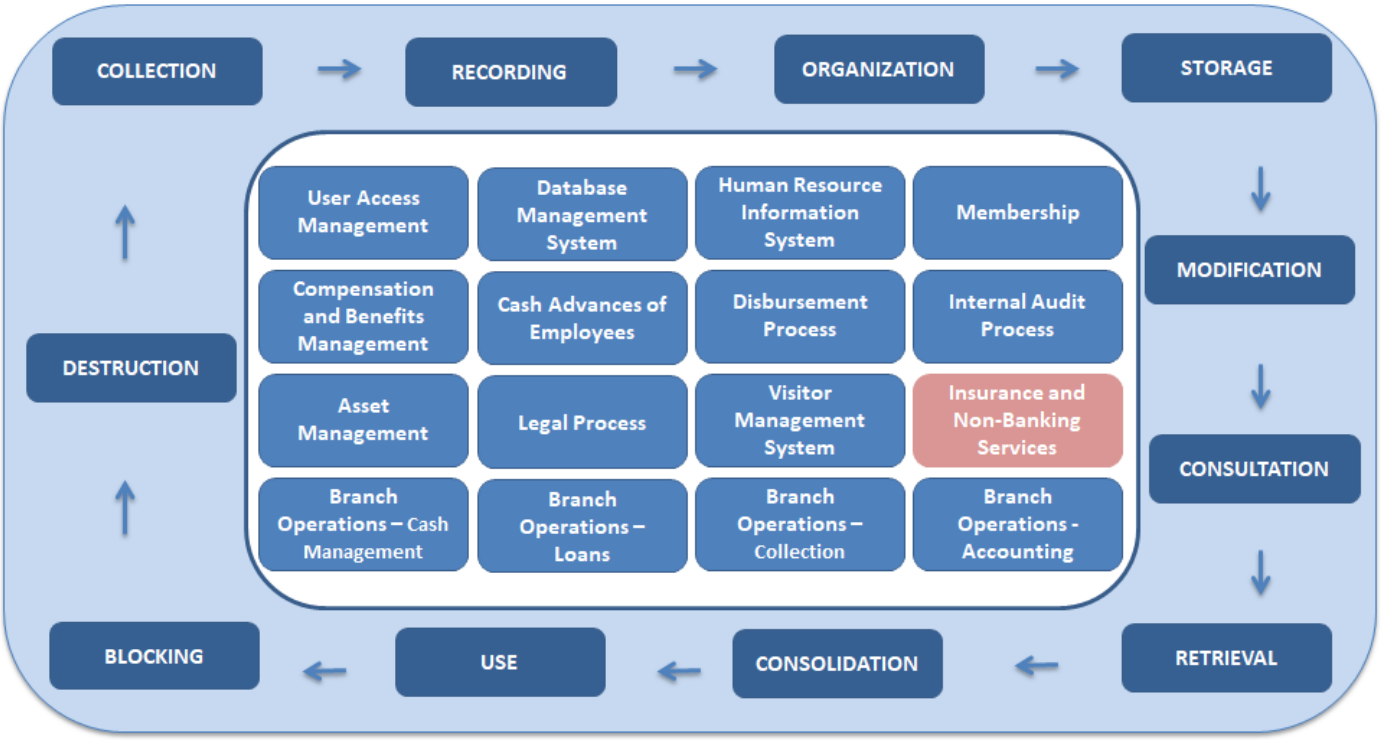

Figure 1. High level scope

Details of each registered DPS and the respective data subjects involved are presented in the table below.

No.	DPS Name	Managed As?	Purpose	Data Subject Category	DPS Type	Automated Decision Making System?	With Cross-Border Transfers?
Administrative Department							
01	Visitor Management System	PIC	Monitors employees and visitors' log in and log out credentials to ensure only authorized employees and visitors may enter the Cooperative's premises	Member, Employee, Visitor	Both	No	No
Asset Management Department							
02	Foreclosure of Collaterals (i.e., Real and Personal Properties) of Delinquent Borrowers	PIC	Facilitates processing of foreclosure of collaterals (i.e., real and personal property) to pursue collection of receivables from delinquent borrowers	Member	Manual	No	No
03	Sale of Foreclosed Real and Personal Properties	PIC	Facilitates sale of foreclosed real and personal properties and collects the receivables from the sales proceeds as payment of delinquent borrowers	Member	Manual	No	No
04	Construction Management	PIC	Manages and monitors construction projects of the Cooperative	Contractor	Both	No	No
05	Bidding Process	PIC	Facilitates the bidding process (i.e., from vendor sourcing to selection) for the Cooperative's procurement of goods and services	Vendor Representative	Manual	No	No
Education and Training Committee							
06	Trainings	PIC	Facilitates trainings of the Cooperative's employees for continuous development and career growth	Employee	Manual	No	No
07	Pre-Membership Seminar (PMS)	PIC	Facilitates the conduct of pre-membership seminars	Member	Manual	No	No
08	Volunteer Profiling	PIC	Monitors personal information of volunteers to track their status as either active or inactive	Member	Manual	No	No
09	Membership Movement Reporting	PIC	Prepares monthly reports to the management and board of directors about membership movement (i.e., new, inactive / dormant, and withdrawal) of the Cooperative	Member	Manual	No	No
Finance Department							
10	Compensation and Benefits Management	PIC	Prepares the salary computations of employees and takes charge over compliance with the statutory requirements (e.g. SSS Act, Phil health Law, HDMF Act, Tax Code and Labor Code)	Employee	Both	No	Yes

No.	DPS Name	Managed As?	Purpose	Data Subject Category	DPS Type	Automated Decision Making System?	With Cross-Border Transfers?
11	Cash Advances of Employees (main office)	PIC	Processes cash advances of main office's employees	Employee	Both	No	No
12	Disbursement Process (main office)	PIC	Processes disbursements of the main office and ensures its validity, accuracy, reasonableness and adequacy	Employee, Vendor	Both	No	No
Human Resource Department							
13	Recruitment and Placement	PIC	In charge of selection and hiring for the various personnel requirements of the Cooperative	Applicant	Manual	No	No
14	Employee Master File Maintenance	PIC	Maintains employee's 201 files	Employee	Manual	No	No
15	Timekeeping	PIC	Monitors attendance, overtime, leaves, official business and tardiness of employees	Employee	Both	No	No
16	Performance Appraisal	PIC	In charge of employee evaluation documents	Employee	Manual	No	No
17	Cessation of Employment	PIC	Processes resignation, retirement, termination, end of contract of Cooperative's employees	Employee	Manual	No	No
18	Grievance Handling	PIC	In charge of disciplinary action for employees violating the Cooperative's Employee policies and procedures and code of conduct	Employee	Manual	No	No
Information Technology Department							
19	User Access Management	PIC	Manages granting of access rights (user account creation, modification, and deactivation) in the information system and ensures appropriate access levels in accordance with the job description	Employee	Electronic	No	No
20	Database Management System	PIC	Manages the database of the Cooperative including storage and back-ups	Member, Employee, Vendor Representative	Both	No	No
21	Incident Management	PIC	Manages incidents related to IT operations (e.g., laptop repairs)	Employee	Manual	No	No
Insurance and Non-Banking Department							
22	Processing of Insurance Applications	PIP	Processes insurance applications of members and facilitates submission of applications and supporting documents to respective insurance providers	Member	Both	No	No
23	Management of Other Services	PIP	Manages other services being offered to members by the partners of the Cooperative. Other services include payment of 4Ps, Skydirect subscriptions,	Member	Both	No	No

No.	DPS Name	Managed As?	Purpose	Data Subject Category	DPS Type	Automated Decision Making System?	With Cross-Border Transfers?
			GCash services, Shell and Petron credit purchases, availment of business capped plan from Globe Telecom, credit purchases with discounts of OPPO smartphones and Pureit water purifier from Unilever Philippines				
Internal Audit Department							
24	Internal Audit Process	PIC	Provides independent, objective assurance and consulting activity designed to add value and improve Cooperative's operations. It helps the Cooperative to accomplish its objectives by bringing a systematic, disciplined approach to evaluate and improve the effectiveness of risk management, control and governance processes	Employee, Member, Vendor	Both	No	No
Legal Department							
25	Notarization of Loan Documents	PIC	In charge of ensuring immediate resolution of cases involving the Cooperative	Borrower	Manual/ Paper-based	No	No
26	Case Management	PIC	Ensures compliance of the Cooperative with relevant laws and regulations such as the Cooperative Code, Credit Information System Act, Tax Code, DPA and etc.	Employee, Member	Manual/ Paper-based	No	No
27	Legal Assistance to the Cooperative in Compliance with Relevant Laws and Regulations	PIC	In charge of providing legal assistance to the Cooperative's stakeholders in case of litigation, disputes and other legal matters	Employee, Member	Manual/ Paper-based	No	No
28	Legal Assistance to the Cooperative's Directors, Officers, Employees and other Stakeholders	PIC	In charge of ensuring immediate resolution of cases involving the Cooperative	Employee	Manual/ Paper-based	No	No
Branch Operations – Accounting Department							
29	Disbursement Process (branch operations)	PIC	Processes disbursements of the branches and ensures its validity, accuracy, reasonableness and adequacy	Employee	Both	No	No
30	Cash Advances of Employees (branch operations)	PIC	Processes cash advances of branch's employees	Employee	Both	No	No
31	Creation of Personal Identification Number (PIN)	PIC	Facilitates issuance of PIN code to member's accounts	Member	Both	No	No
32	Withdrawal of Membership	PIC	Manages membership withdrawal	Member	Both	No	No

No.	DPS Name	Managed As?	Purpose	Data Subject Category	DPS Type	Automated Decision Making System?	With Cross-Border Transfers?
33	Interbranch Transfer of Members	PIC	Manages transfer of membership from originating branch to another branch	Member	Manual	No	No
34	Interbranch Withdrawal	PIC	Caters to Interbranch withdrawal of the member	Member	Both	No	No
Branch Operations – Cash Department							
35	Vault Management	PIC	Manages vault operations such as opening and closing of cash-in-vault, access of authorized personnel, etc.	Employee	Manual	No	No
36	Deposits	PIC	Processes deposits of the members and ensures that deposits are recorded and properly supported	Member	Both	No	No
37	Withdrawals	PIC	Processes withdrawals of the members and ensures that withdrawals are recorded and properly supported	Member	Both	No	No
38	New Accounts Management	PIC	Processes application and related requirements for membership to ensure eligibility of the applicants	Member	Both	No	No
Branch Operations – Collections Department							
39	Collection Process	PIC	In charge in the collection of receivables from borrowers	Member	Manual	No	No
40	Handling of Delinquent Accounts Referred to Legal	PIC	In charge of handling delinquent accounts by referring them to legal department to pursue collection from the borrowers	Member	Manual	No	No
41	Loan Restructuring	PIC	In charge of providing other options for settlement by borrowers with delinquent accounts	Member	Manual	No	No
Branch Operations – Loans Department							
42	Loans Processing	PIC	Handles and manages loans to ensure that they are granted to eligible members, authorized, recorded and properly supported	Member	Manual	No	No

A data processing activity is considered to have cross-border transfers when somewhere during its processing, a piece of personal information is transferred outside of the Philippines. The Cooperative does not observe cross-border transfers.

Please see Appendices C.01 to C.10 for the complete list of personal data processed for each DPS.

The PIPs of the Cooperative are listed below.

PERSONAL INFORMATION PROCESSOR	RELATED DATA PROCESSING SYSTEM	EXTENT OF PROCESSING
Thirty-seven (37) contracted legal retainers: <u>Region I</u> Main — Atty. Noel G. Bacal Cebu — Atty. Ivy Grace Nogoy-Llido Carmen — Atty. Felix P. Saarenas Tiano — Atty. Felix P. Saarenas Cogon — Atty. Juvy IND Dela Victoria Arubio Villanueva — Atty. Juvy IND Dela Victoria Arubio Lapasan — Atty. Kenneth O. Tamela Opol — Atty. Lynn Amor Panulaya Bohol — Atty. Dionisio A. Galido Puerto — Atty. Robert W. Raypon <u>Region II</u> Alubijid — Atty. Perfecto Justino A. Mendoza Naawan — Atty. Eddie C. Cuaresma Iligan — Atty. Zaldy C. Lim Ozamis — Atty. Diogenes B. Apao Jr. Maranding — Atty. Nestle S. Agopitac Pagadian — Atty. Emiliano R. Deleverio <u>Region III</u> Balingasag — Atty. Ma. Cristina Moreno-Ociones Balingoan — Atty. Michelle Anayron Bayugan — Atty. Genesis E. Efren Gingoog — Atty. Margie Lumaad Surigao — Atty. Victor Marc B. Lumaad Butuan — Atty. Dendo Udarbe Cabadbaran — Atty. Dendo Udarbe Camiguin — Atty. Avelino P. Orseno Jr. San Franz — Atty. Carlito B. Ranoco <u>Region IV</u> Don Carlos — Atty. Elizabeth Anne Y. Aganap Kibawe — Atty. Elizabeth Anne Y. Aganap Maramag — Atty. Rolando B. Lopez Kalilangan — Atty. Rolando B. Lopez manolo — Atty. Mario Narciso C. Albarece Malaybalay — Atty. Anastacio C. Rosos, Jr Aglayan — Atty. Anastacio C. Rosos, Jr Valencia — Atty. Febbie A. Cupida-Legita <u>Region V</u> Tagum — Atty. Numeriano P. Galgo, Jr. Tandag — Atty. Kutz Melvin G. Montenegro Toril — Atty. Jose Dionisio N. Guevarra, Jr. Davao — Atty. Stephen Don Q. Munez	Notarization of Loan Documents, Legal Assistance to the Cooperative's Directors, Officers, Employees, and other Stakeholders	Provide legal services such as notarization of loan documents (i.e., promissory notes), and assistance to the Cooperative's stakeholders in case of litigation, disputes and other legal matters
Amigas Security & Investigation Agency, Inc.	Security Management	Provide security services to the Cooperative including all branches
Globe Telecommunications, Inc.	Database Management System, Compensation and Benefits Management, Loans Processing, Collection Process, Deposits, Withdrawals	Provide space for offsite back-up storage facility in Cebu City, GCash account management

Part 3
DATA PRIVACY GOVERNANCE ASSESSMENT

This section evaluates the overall commitment of FICCO to privacy and data protection in respect to their compliance with the Act, taking into account the existing organizational structure, policies and procedures during the assessment. The assessment made on three levels, namely People, Process and Technology, is summarized below.

GOVERNANCE COMPONENT		REMARKS
PEOPLE "Aware" Culture	Commitment of the Board	ⓘ
	Involvement of the Management Committee	ⓘ
	Integrated governance organization	✓
	Trained, aware and accountable personnel	✗
PROCESS "Embedded" Processes	Structured and repeatable process	✗
	Harmonized frameworks and standards	ⓘ
	Practical and enforceable policies	ⓘ
	Effective internal control environment	✓
TECHNOLOGY "Enabled" Technology	Secure infrastructure	✓
	Effective identity and access control management	ⓘ
	Effective information protection mechanism	ⓘ
	Auditing and reporting	ⓘ

Legend:
- ✓ Controls are adequate
- ⓘ Areas for improvement are noted
- ✗ Controls are inadequate

PEOPLE

Effective governance requires an appropriate organizational structure with clearly defined roles and responsibilities, enough resources to perform required duties, and clear guidance on the overall goals and data privacy objectives.

The Cooperative's top management is aware of and responsive to the requirements of the Act. A Data Protection Officer was registered with the NPC on September 09, 2017. However, the degree of involvement of the Cooperative's management with privacy matters can still be improved through integrating privacy management into the operations risk management and reporting function.

The Cooperative's current organizational structure facilitates the implementation of a privacy management program. Functional units can manage the impact of the requirements of the Act on their respective processes, through the guidance of a data privacy compliance team.

Upon the establishment of the Cooperative's privacy management program, employees should undergo awareness and training sessions to equip them with the necessary knowledge and skills to the comply with the Act.

PROCESS

In order to implement effective and efficient data privacy practices, organizations must define a set of guiding principles that can be applied to each core process.

Inasmuch as the Act is still in its early years of implementation, most of its requirements are not yet embedded into the Cooperative's core processes. Privacy principles still have to be assimilated in the Cooperative's activities through the adoption of Privacy Policies and Guidelines.

While formal adoption is still pending, it is noteworthy that the existing policies and manuals of the Cooperative immediately lend themselves for inclusion of provisions for compliance with data protection requirements.

TECHNOLOGY

An organization has to ensure data confidentiality, integrity and availability across its IT infrastructure. In order to implement this, an organization must have effective control mechanisms over the following technology domains:

- Secure infrastructure
- Identity and access control
- Information protection
- Auditing and reporting

Generally, the Cooperative has mechanisms in place to effectively manage the stated technology domains. However, it needs to revisit these mechanisms to ensure full compliance with the requirements of the Act. Additional details are discussed in the Technical Assessment section of this report.

Part 4

DATA PRIVACY MANAGEMENT ASSESSMENT

This section presents the impact of the requirements of the Act on each of the data processing systems of the Cooperative. Several DPS were merged and assessed collectively, taking into account the nature of the processes. (Please see below.)

DPS Group	DPS Included
Branch operations -Cash Management	Vault Management
	Deposits
	Withdrawals
	New Accounts Management
Branch operations -Loans	Loans Processing
Branch operations-Collections	Collection Process
	Handling of Delinquent Accounts Referred to Legal
	Loan Restructuring
Branch operations-Accounting	Disbursement Process (branch operations)
	Cash Advances of Employees (branch operations)
	Creation of Personal Identification Number (PIN)
	Withdrawal of Membership
	Interbranch Transfer of Members
	Interbranch Withdrawal
User Access Management	User Access Management
Database Management System	Database Management System
Human Resource Information System	Recruitment and Placement
	Employee Master File Maintenance
	Timekeeping
	Performance Appraisal
	Cessation of Employment
	Grievance Handling
Membership	Pre-Membership Seminar (PMS)
	Membership Movement Reporting
	Trainings
	Volunteer Profiling
Compensation and Benefits Management	Compensation and Benefits Management
Cash Advances of Employees	Cash Advances of Employees (main office)
Disbursement Process	Disbursement Process (main office)
Internal Audit Process	Internal Audit Process
Asset Management	Foreclosure of Collaterals (i.e., Real and Personal Properties) of Delinquent Borrowers
	Sale of Foreclosed Real and Personal Properties
	Construction Management
	Bidding Process

DPS Group	DPS Included
Legal Process	Notarization of Loan Documents
	Case Management
	Legal Assistance to the Cooperative in Compliance with Relevant Laws and Regulations
	Legal Assistance to the Cooperative's Directors, Officers, Employees and other Stakeholders
Visitor Management System	Visitor Management System
Insurance and Non-Banking Services	Processing of Insurance Applications
	Management of Other Services

COMPLIANCE WITH DATA PRIVACY PRINCIPLES

Figure 2 presents the compliance level of the Cooperative in relation to the privacy principles of transparency, legitimate purpose and proportionality.

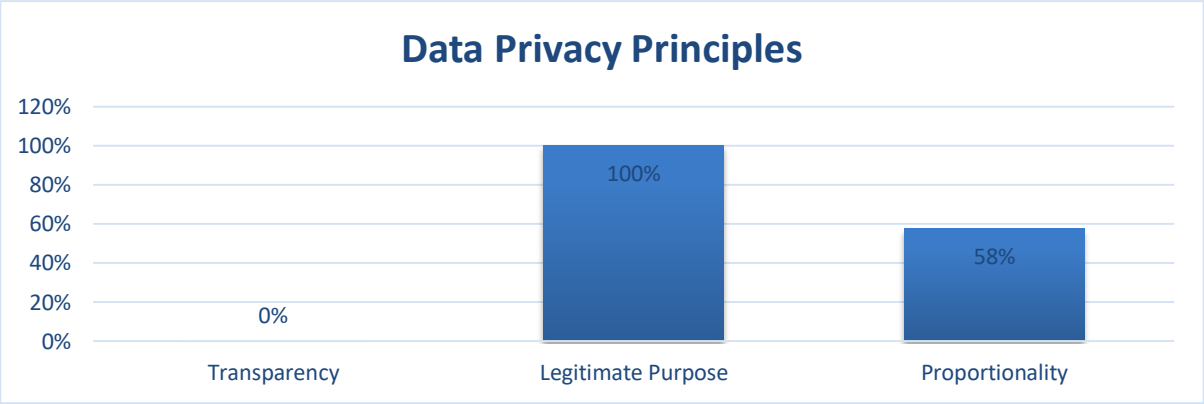

Figure 2. Privacy principles compliance level

Transparency

The principle of transparency requires that data subjects must be aware of the nature, purpose and extent of processing of their personal data. As a PIC, the Cooperative should have appropriate mechanisms in order to inform its data subjects such information as required by the Act to be disclosed.

Overall, the Cooperative is not transparent to its data subjects. It is generally expected that data subjects should be aware of the purpose of processing of their personal data, most especially in cases when the data subjects directly provide their information to the Cooperative. However, as required by the Act, the Cooperative should also be able to provide information on the identities of personal information processors engaged by the Cooperative for the processing of personal data, which the Cooperative failed to do so as of the period of assessment.

At the time of the conclusion of the assessment period, the Cooperative has initiated drafting Privacy Statements to append to its data collection forms to conform to transparency principles of the Act with their data subjects.

Legitimate Purpose

The principle of legitimate purpose requires that processing of personal data should have a declared and specified purpose that is not contrary to law, morals, or public policy.

The Cooperative processes the personal data of its data subjects for legitimate purposes. The level of non-compliance noted under this principle points to the lack of documented consent although it should be noted that the consent requirement is optional for certain data processing systems of the Cooperative as they comply with the other criteria for lawful processing of personal data as provided by Sections 12 and 13 of the Act.

Proportionality

The principle of proportionality requires that processing of personal data should be adequate, relevant, suitable, necessary and not excessive in relation to the declared and specified purpose, and that processing cannot be reasonably fulfilled by other means.

Non-compliance noted for this principle focuses on the pieces of personal information in certain documents that were deemed unnecessary to achieve the purpose of the document itself. Such collection is deemed excessive in respect of the purpose, and would require the Cooperative to reassess the need to collect such information.

Beyond the point of collection, non-compliance with the proportionality principle is also manifested in the absence of appropriate retention period for the information collected. Currently, the Cooperative has no written policies and procedures for retention and storage of documents. Eventual destruction and disposal of such documents and its procedures are currently executed through subjective assessment whether such documents are no longer needed.

COMPLIANCE WITH PERSONAL DATA PROCESSING REQUIREMENTS

Figure 3 presents the level of compliance of FICCO in relation to the requirements of each stage of processing as defined by the Act.

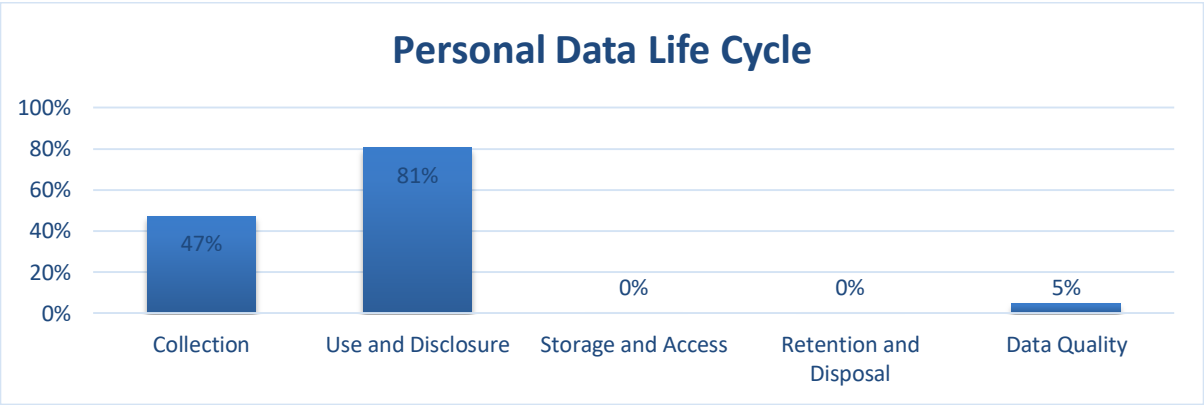

Figure 3. Data life cycle general principles compliance level

It has to be emphasized that the data privacy principles should be observed in each stage of personal data processing. As such, the assessment discussed in this section is reflective of the discussion in the previous section.

Collection

Collection of personal data performed by the Cooperative is assessed to be partially non-compliant with the Act primarily due to the absence of documented consent for the collection and processing of personal data.

It should be noted that whenever the Cooperative gathers information from other organizations, except from the PIPs, there may be a need to execute a Data Sharing Agreement between FICCO and such organization. There is an existing Data Sharing Agreement with one organization, however it lacks several provisions to ensure the Cooperative can enforce its rights to retain personal data they deem to be excessive to share with its co-party.

Use and Disclosure

Use of the personal data by the Cooperative is limited only to the primary purposes for which they were collected and as authorized by law. The personal data are also disclosed only to parties who are authorized to receive such, either by virtue of the mandate of a government agency or the engagement of a personal information processor.

The non-compliance noted is due to the absence of a privacy policy and notices to properly inform data subjects of the purposes of the collection and processing of personal data.

Storage and Retention

Storage of personal data by the Cooperative is assessed to be completely non-compliant due to the absence of written policies and procedures for storage and retention for most of its documents and records. Despite the absence of written policies and procedures, a number of controls are in place to limit access to the storage of personal data, whether in electronic or in hard copy formats through user access management and physical controls. Specifically, physical access restrictions are significant in the Cooperative as this has been underlined by its operations. Logical access restrictions are also expected to be improved moving forward with the expected information security program to be launched by the Cooperative.

Disposal and Destruction

Following the absence of defined retention periods, the disposal procedures for some documents are also not formally established. Disposal and destruction of documents and files are generally executed through the use of vertical cut shredders.

The Cooperative should ensure the appropriateness and adequacy of its disposal procedures in order to mitigate the risks associated with dumpster diving and similar information security threats. In line with ensuring disposal security, the engagement team suggests cross-shredders to effectively wipe out personal data.

Data Quality

The Cooperative is generally non-compliant in the area of data quality due to the lack of regular review of personal data maintained to ensure the accuracy of the data. The Cooperative usually relies on the data subject to inform them of any change to their information, as in the case of employees, bank relationship managers, and sole proprietors transacting with the Cooperative.

Below is the summary of the assessment made on the technical security measures of the Cooperative against the requirements of Section 28 of the IRR.

SECTION 28 OF THE IRR		SECURITY MEASURE	REMARKS
A	Security policy in respect of the processing of personal data	Privacy Policy	✗
B	Safeguards to protect the computer network	Network Security	ⓘ
		Endpoint Security	ⓘ
		Access Control Management	ⓘ
		Physical & Environmental Security	ⓘ
C	Confidentiality, integrity, availability, and resiliency of the processing systems, and services	Information Security Policy	ⓘ
		Disaster Recovery Plan	✗
		System Acquisition and Development	ⓘ
		Program Change Management	ⓘ
D	Regular monitoring for security breaches, and a process both for identifying and assessing vulnerabilities in the computer network	Technical Vulnerability Mangement	✗
		Patch Management	ⓘ
		Incident Management	ⓘ
		IT Asset Management	ⓘ
E	Availability of and access to personal data in a timely manner in the event of a physical or technical incident	Back-up and Recovery Management	✓
F	Regular testing, assessment, and evaluation of the effectiveness of security measures	Information Security Policy – Management System and Policy Review	ⓘ
G	Encryption of personal data during storage and while in transit	Encryption Management	✗

Legend:

- ✓ Controls are adequate
- ⓘ Areas for improvement are noted
- ✗ Controls are inadequate

The Cooperative's current state is generally non-compliant with the requirements of Section 28. The IT function performs adequate procedures to support operations. However, these procedures are not properly established due to the absence of IT Policies, Standards and Guidelines.

Specific areas of improvement in technical security include the adoption of a privacy policy to ensure the security of personal data processing, and the implementation of an information security program. An established information security program leads to the formal testing, assessment and evaluation of the effectiveness of the security measures in place.

It is noteworthy that despite having good IT security practice such as user access management and other technical controls, the absence of regular testing and evaluation of the effectiveness of security controls has a big impact on the assessed compliance level of the Cooperative. This emphasizes the need for an independent function that monitors the implementation of the existing security controls of the Cooperative in respect of complying with the Act.

CROSS-BORDER DATA TRANSFER

The different data processing systems identified to have cross-order transfers are considered compliant if any of the following has been observed:

- The data subject consents or would likely consent to the transfer, unless obtaining of consent is not practicable;
- The Cooperative reasonably believes that the recipient is subject to laws or a contract enforcing information-handling principles substantially similar to the Act; or,
- The transfer is necessary as part of a contract between the organization and a third party for the interest of the data subject.

Relevant terms and conditions with concerned entities facilitating the transfer (e.g., Google) and their respective publicly available privacy policies were assessed to be appropriate and adequate insofar as the foregoing criteria are concerned.

Part 5

PRIVACY RISK ASSESSMENT

The Privacy Risk Assessment examines risk following the data privacy principles, rights of the data subject and measures in place to ensure confidentiality, integrity and availability of personal data as required by law. Once privacy risks are evaluated, the appropriate privacy risk treatment option is determined among the available alternatives.

For this purpose, the methodology suggested by the National Privacy Commission in its NPC Privacy Toolkit 2nd edition was used. This methodology focuses on the impact of the identified risks to the data subjects, multiplied by a factor of its probability of occurring. Details of the NPC methodology are discussed in the annexes.

Figure 5 presents the distribution of the different risks following the NPC methodology.

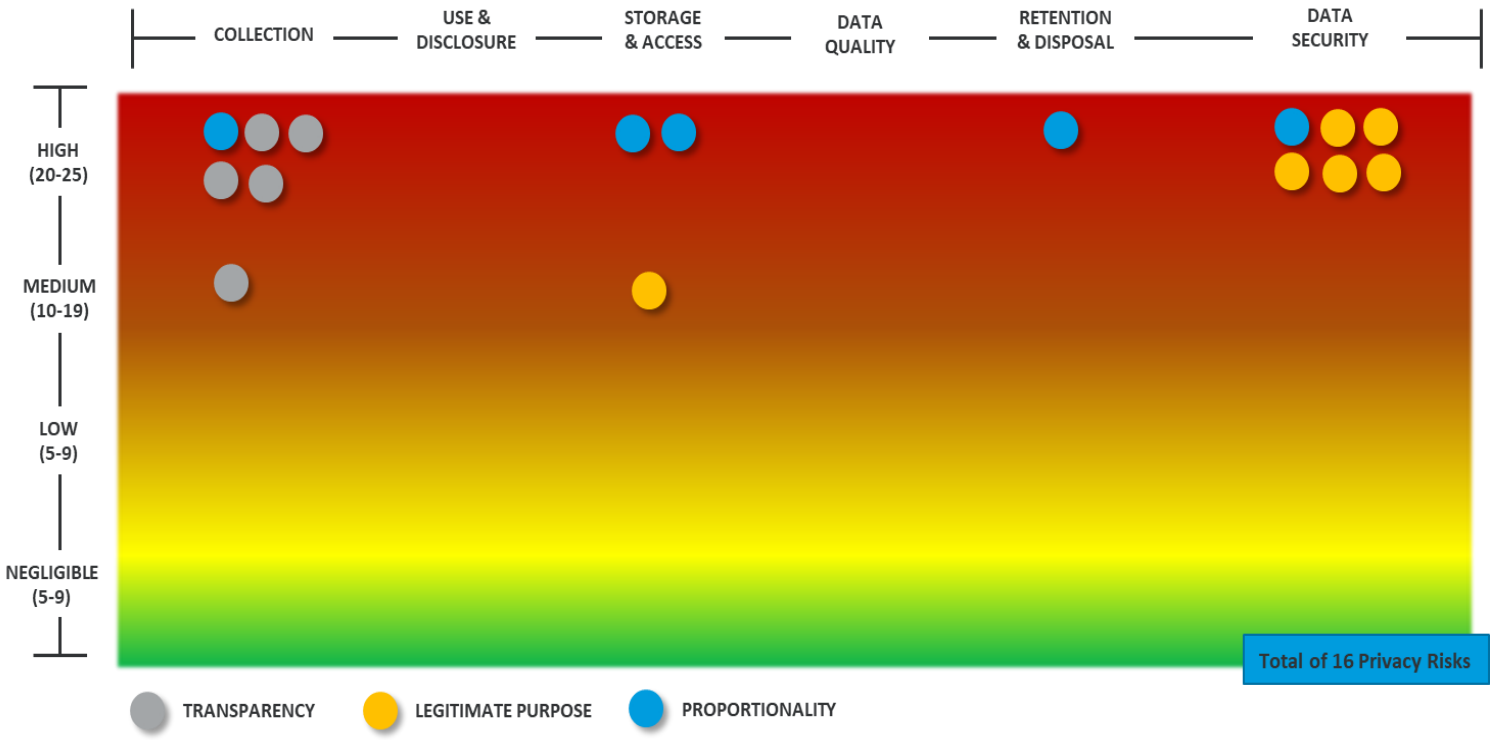

Figure 5. Risk heat map using NPC Risk Assessment Methodology

The risks tend to concentrate in the area of data security, primarily as a result of the absence of relevant policies on privacy management and IT operations during the period when the Cooperative could have implemented such (i.e., from the time the IRR of the Act has been released) as well as the non-implementation of a general information security program.

These risks may, individually or collectively, expose the Company to the following unless addressed soon:

- Limited resiliency in responding to Data Privacy Breaches
- Exposure to compliance audits/orders from the NPC in the instance of data privacy breaches and complaints
- Damage to the Company's reputation

Appendix B.1.0 Provides the detailed risk scoring assessment made for the privacy risks identified for the Cooperative, while **Appendix B.2.0** provides the details of these privacy risks, together with the action plan for each risk agreed with the Cooperative's management. The highlights of the management action plan are likewise presented in the next section of this report, **Priority Action Plan**.

NO.	RISK AREA	OBSERVATION	PRIVACY PRINCIPLE	NPC RISK RATING	CRITICALITY
01	Cross-organizational	Absence of storage and retention policies and procedures	Proportionality	16	High Risk
02	Cross-organizational	Absence of disposal and destruction policies and procedures	Proportionality	16	High Risk
03	• Information Technology • Human Resource	Inadequate access control administration	Proportionality	16	High Risk
04	Human Resource, Education and Training Committee	Excessive collection of personal data in relation to the purposes for which they are collected on certain forms and being processed	Proportionality	16	High Risk
05	Information Technology, Branch Management	Insufficient technical security measures in place	Legitimate Purpose	16	High Risk
06	Cross-organizational	Lack of documented consent from data subjects and a Data Privacy Policy Statement in forms that collect personal data	Transparency	16	High Risk
07	Administrative Department, Branch Management	Absence of banner related to monitoring the activities of data subjects by capturing video footage through security cameras (e.g., CCTV)	Transparency	16	High Risk
08	Information Technology	Absence of Information Security Policies or Programs	Legitimate Purpose	16	High Risk

NO.	RISK AREA	OBSERVATION	PRIVACY PRINCIPLE	NPC RISK RATING	CRITICALITY
09	Administrative Department, Information Technology	Absence of business continuity plan and procedures	Legitimate Purpose	16	High Risk
10	Information Technology	Absence of IT Service Delivery Policies and Procedures	Legitimate Purpose	16	High Risk
11	Administrative Department, Legal Department, Insurance and Non-Banking Department	Absence of data privacy provisions in the Data Sharing Agreements with the Personal Information Processors	Legitimate Purpose	16	High Risk
12	Insurance and Non-Banking Department	Absence of contact details of Personal Information Controllers(e.g. third party insurance providers)	Transparency	8	Medium Risk
13	Administrative Department, Human Resource	Unsecured steel cabinets which contain documents with Personal Data	Proportionality	16	High Risk
14	Information Technology	Absence of banner or notification to employees that their activity within the Cooperative's VPN is monitored	Transparency	16	High Risk
15	Cross-organizational	Non-publication and communication of contact details of the Data Protection Officer	Transparency	16	High Risk
16	Human Resource, Finance Department	Improper handling of Payroll Master List	Legitimate Purpose	9	Medium Risk

Part 6
PRIORITY ACTION PLAN

Based on the assessment made on the identified risks, taking into account their impact on both the Cooperative and its data subjects, an action plan was developed. This action plan aims to close the identified gaps affecting personal data processing as noted during the walkthrough and process owners' confirmation ending October 18, 2018. The implementation of this action plan is the accountability of the Data Protection Officer, with the assistance from the different functional units of the Cooperative.

As of date of this report, implementation of the action plan has commenced.

Retention, Storage, Disposal and Destruction of Personal Data

1. The respective department heads are to evaluate documents containing personal data and identify their appropriate retention period. For documents whose retention has already been identified, the department heads shall, likewise, evaluate the appropriateness of such retention period.

2. Document the assessment made through integrating the identified retention periods in the respective policies and or procedures governing each document.

3. Dispose of or delete all documents and files that are past its retention period. Appropriate resources to carry out the disposal procedures like cross-shredders and data wiping tools should be considered.

Data Privacy Governance

1. Approve and implement the following high-level data privacy documents, following the Cooperative's Document Control Procedure:
   - Data Privacy Governance and Management Framework
   - Data Privacy Governance and Management Policy
   - Data Privacy Management Guidelines and Procedures

2. Disseminate the approved framework, policy, guidelines and procedures to all employees, subject to the protection measures in the Cooperative's Information Classification Standard.

3. Conduct follow-through activities to ensure that the employees have read, understood and follow the data privacy guidelines.

Transparency in Personal Data Processing

1. Draft a Privacy Notice aligned with the Cooperative's approved privacy policy to be posted in the Cooperative's website, data collection forms and social media accounts, taking into consideration the requirements of the Act, specifically those that are stated under the provision on the data subject's right to be informed.

Documenting Consent of the Data Subject

1. Review existing forms that collect personal information to identify the need for a consent or privacy statement. If the processing requires the consent of the data subject, a consent statement should be included in the form; otherwise, a privacy statement (i.e., a statement that references the Cooperative's privacy policy and privacy notice) would suffice.

2. Revise the forms as needed and roll out to production.

3. Moving forward, all forms that will be used in future projects and/or processes of the Cooperative that are not included in this assessment shall likewise follow the same review procedure prior to implementation.

Other Action Items

1. Fast track the implementation of the Cooperative's information security program.

2. Review existing contracts with third party service providers and execute the draft Data Sharing Agreement that has been drafted by the Legal Department whenever necessary.

3. Integrate periodic system review procedures and regular testing, assessment and evaluation on the effectiveness of the security measures in the Cooperative's policies.

Part 8
SIGN-OFF

This is to certify that the undersigned has accepted this report which summarizes the results of and evidences the conduct of the Privacy Impact Assessment (PIA) for this period. This further certifies that the PIA for this period is an appropriate basis for the action plans that will be implemented by the respective process owners as part of FICCO's efforts to achieve substantial compliance with the Act, its IRR, and other pertinent laws and regulations. In summary, the conduct of this period's PIA and the agreement thereto by key personnel are evidenced by the following document and its appendices and annexes:

Document: PRIVACY IMPACT ASSESSMENT REPORT

Appendices

1) Data Flow Diagram
2) Data Inventory
3) Privacy Impact Analysis
4) Risk Assessment and Risk Treatment Plan

Annexes

1) Privacy Impact Assessment Methodology
2) Privacy Risk Management Methodology

Shiellou P. Jabonga
Data Protection Officer